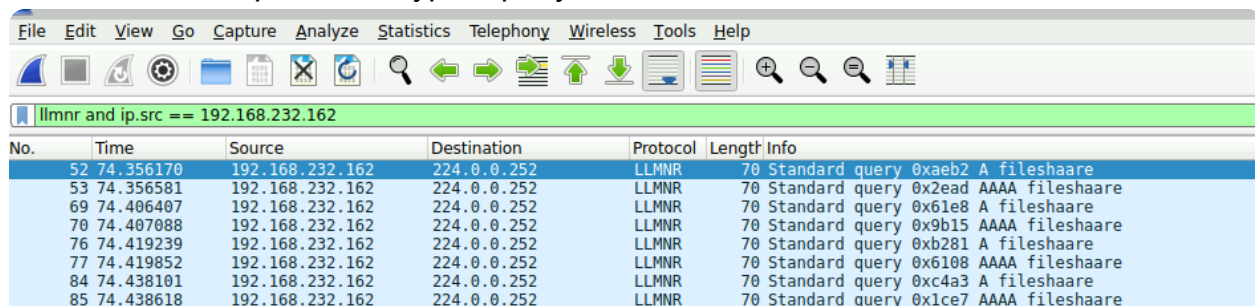


PoisonedCredentials Lab

Link of Completion: <https://cyberdefenders.org/blueteam-ctf-challenges/achievements/sPo0f1ng/poisonedcredentials/>

Q1. In the context of the incident described in the scenario, the attacker initiated their actions by taking advantage of benign network traffic from legitimate machines. Can you identify the specific mistyped query made by the machine with the IP address 192.168.232.162?

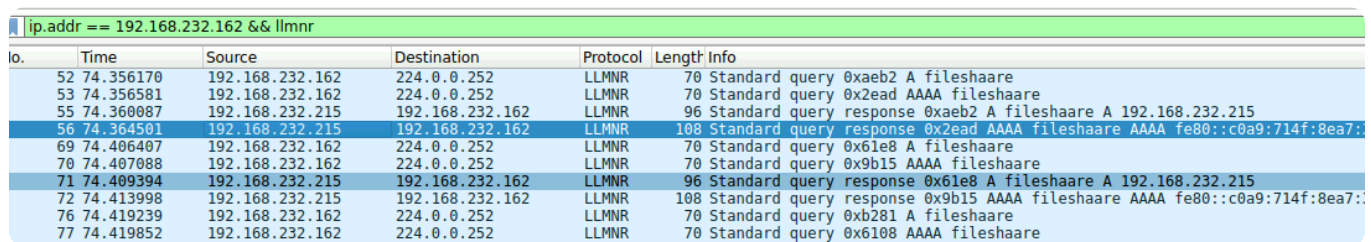
to find the answer for this question, i use the filter, llmnr and ip.src == 192.168.232.162 and look for the specific mistyped query



No.	Time	Source	Destination	Protocol	Length	Info
52	74.356170	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0xaeb2 A fileshaare
53	74.356581	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x2ead AAAA fileshaare
69	74.406407	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x61e8 A fileshaare
70	74.407088	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x9b15 AAAA fileshaare
76	74.419239	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0xb281 A fileshaare
77	74.419852	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x6108 AAAA fileshaare
84	74.438101	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0xc4a3 A fileshaare
85	74.438618	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x1ce7 AAAA fileshaare

Q2. We are investigating a network security incident. To conduct a thorough investigation, We need to determine the IP address of the rogue machine. What is the IP address of the machine acting as the rogue entity?

still on that section filter, i just look for the no response query to locate which ip address are acting



No.	Time	Source	Destination	Protocol	Length	Info
52	74.356170	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0xaeb2 A fileshaare
53	74.356581	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x2ead AAAA fileshaare
55	74.360087	192.168.232.215	192.168.232.162	LLMNR	96	Standard query response 0xaeb2 A fileshaare A 192.168.232.215
56	74.364501	192.168.232.215	192.168.232.162	LLMNR	108	Standard query response 0x2ead AAAA fileshaare AAAA fe80::c0a9:714f:8ea7::
69	74.406407	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x61e8 A fileshaare
70	74.407088	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x9b15 AAAA fileshaare
71	74.409394	192.168.232.215	192.168.232.162	LLMNR	96	Standard query response 0x61e8 A fileshaare A 192.168.232.215
72	74.413998	192.168.232.215	192.168.232.162	LLMNR	108	Standard query response 0x9b15 AAAA fileshaare AAAA fe80::c0a9:714f:8ea7::
76	74.419239	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0xb281 A fileshaare
77	74.419852	192.168.232.162	224.0.0.252	LLMNR	70	Standard query 0x6108 AAAA fileshaare

Q3. As part of our investigation, identifying all affected machines is essential. What is the IP address of the second machine that received poisoned responses from the rogue machine?

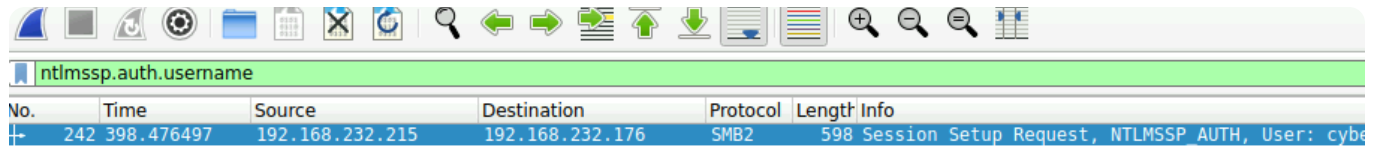
for this part of the question, the filter that i use from this one is just a simple ip address locator and the poisoned ip address

ip.addr == 192.168.232.215					
No.	Time	Source	Destination	Protocol	L
71	74.409394	192.168.232.215	192.168.232.162	LLMNR	
72	74.413998	192.168.232.215	192.168.232.162	LLMNR	
75	74.418538	192.168.232.215	192.168.232.162	MDNS	
78	74.420725	192.168.232.215	192.168.232.162	MDNS	
79	74.422420	192.168.232.215	192.168.232.162	LLMNR	
80	74.426719	192.168.232.215	192.168.232.162	LLMNR	
83	74.437753	192.168.232.215	192.168.232.162	MDNS	
86	74.439411	192.168.232.215	192.168.232.162	MDNS	
87	74.441497	192.168.232.215	192.168.232.162	LLMNR	
88	74.445950	192.168.232.215	192.168.232.162	LLMNR	
145	249.286604	192.168.232.215	192.168.232.176	NBNS	
146	249.286609	192.168.232.176	192.168.232.215	NBNS	
152	250.280521	192.168.232.215	192.168.232.176	NBNS	
153	250.280526	192.168.232.176	192.168.232.215	NBNS	
157	251.281828	192.168.232.215	192.168.232.176	NBNS	
158	251.281834	192.168.232.176	192.168.232.215	NBNS	
161	252.282406	192.168.232.215	192.168.232.176	NBNS	
166	254.178011	192.168.232.215	192.168.232.176	MDNS	
167	254.178176	192.168.232.215	192.168.232.176	NBNS	
170	254.179997	192.168.232.215	192.168.232.176	MDNS	
171	254.182306	192.168.232.215	192.168.232.176	LLMNR	
172	254.186728	192.168.232.215	192.168.232.176	LLMNR	
183	254.228659	192.168.232.215	192.168.232.176	MDNS	
184	254.230005	192.168.232.215	192.168.232.176	MDNS	
187	254.233162	192.168.232.215	192.168.232.176	LLMNR	
188	254.237206	192.168.232.215	192.168.232.176	LLMNR	

Q4. We suspect that user accounts may have been compromised. To assess this, we must determine the username associated with the compromised account. What is the username of the account that the attacker compromised?

for this question, i don't have a knowledge for this part on how to find the username, but thanks for the help of hint from the app it helps me to find the answer and i just got a new knowledge

for this part.. BIG HELP!



The image shows a Wireshark packet capture window. The filter bar at the top is set to 'ntlmssp.auth.username'. The packet list shows a single packet at time 242.398.476497, source 192.168.232.215, destination 192.168.232.176, protocol SMB2, length 598. The packet details pane shows the structure of the SMB2 message, including the Session Setup Request and NTLMSSP_AUTH fields.

No.	Time	Source	Destination	Protocol	Length	Info
242	398.476497	192.168.232.215	192.168.232.176	SMB2	598	Session Setup Request, NTLMSSP_AUTH, User: cybe

```
..... .0.. .... = ENCRYPTION: This host does NOT support ENCRYPTION
Channel: None (0x00000000)
Previous Session Id: 0x0000000000000000
Blob Offset: 0x00000058
Blob Length: 452
  Security Blob [truncated]: a18201c0308201bca28201b8048201b44e544c4d53535000030000001800180040000000201020158000000220
    GSS-API Generic Security Service Application Program Interface
      Simple Protected Negotiation
        negTokenTarg
          responseToken [truncated]: 4e544c4d53535000030000001800180040000000201020158000000220022005a01000012001200
            NTLM Secure Service Provider
              NTLMSSP identifier: NTLMSSP
              NTLM Message Type: NTLMSSP_AUTH (0x00000003)
              Lan Manager Response: 753b8a58d34c24ce242fd5dbc45a7677436528b5e6342a8c
              NTLM Response [truncated]: 0312c0aeaedcc76acff103bcada22c2b901010000000000008030adcd5d04da01436528b5e6342a8c
              Domain name: cybercactus.local
              User name: janesmith
              Host name: WORKSTATION
              Session Key: all1086a38a598de9d4fea3fd82f4155
              [truncated]Negotiate Flags: 0xe2888235, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate
```

Q5.As part of our investigation, we aim to understand the extent of the attacker's activities. What is the hostname of the machine that the attacker accessed via SMB?

in to the same target, i just dig up and try to find what is the name and confirms that the attacker accessed the machine.

Version 10.0 (Build 19041); NTLM Current Revision 15

0060	00 00	01 00	00 00	00 00	40	00 00	00 00	00 00	00 00	00 00	@
0070	00 00	00 00	00 00	00 00	00	00 00	09 00	00 00	00 48	00	H
0080	43 01	a1 82	01 3f	30 82	01 3b	a0 03	0a 01	01 a1			C ?0 ;
0090	0c 06	0a 2b	06 01	04 01	82 37	02 02	0a a2	82 01			+ 7
00a0	24 04	82 01	20 4e	54 4c	4d 53	53 50	00 02	00 00			\$ NTL MSSP
00b0	00 16	00 16	00 38	00 00	00 35	82 89	e2 c8	eb 5e			8 5 ^
00c0	4b 7c	03 76	17 00	00 00	00 00	00 00	00 d2	00 d2			KJ v
00d0	00 4e	00 00	00 0a	00 61	4a 00	00 00	0f 43	00 59			N a J C Y
00e0	00 42	00 45	00 52	00 43	00 41	00 43	00 54	00 55			B E R C A C T U
00f0	00 53	00 02	00 16	00 43	00 59	00 42	00 45	00 52			S C Y B E R
0100	00 43	00 41	00 43	00 54	00 55	00 53	00 01	00 18			C A C T U S
0110	00 41	00 43	00 43	00 4f	00 55	00 4e	00 54	00 49			A C C O U N T I
0120	00 4e	00 47	00 50	00 43	00 04	00 22	00 63	00 79			N G P C " c y
0130	00 62	00 65	00 72	00 63	00 61	00 63	00 74	00 75			b e r c a c t u
0140	00 73	00 2e	00 6c	00 6f	00 63	00 61	00 6c	00 05			s l o c a l
0150	00 3c	00 41	00 63	00 63	00 6f	00 75	00 6e	00 74			< A c c o u n t
0160	00 69	00 6e	00 67	00 50	00 43	00 2e	00 63	00 79			i n g P C c y
0170	00 62	00 65	00 72	00 63	00 61	00 63	00 74	00 75			b e r c a c t u
0180	00 73	00 2e	00 6c	00 6f	00 63	00 61	00 6c	00 05			s l o c a l
0190	00 22	00 63	00 79	00 62	00 65	00 72	00 63	00 61			" c y b e r c a
01a0	00 63	00 74	00 75	00 73	00 2e	00 6c	00 6f	00 63			c t u s l o c
01b0	00 61	00 6c	00 07	00 08	00 21	bc 0d	cd 5d	04 da			a l l j